HASH-MAC-PASSWORD

해시·MAC·솔트·키 스트레칭

연관 기출 · 127-1-5, 138-4-2, 127-1-9

한눈에 이해

해시는 지문, MAC은 비밀키를 가진 이의 지문, 비밀번호 저장은 추측을 느리게 하는 별도의 설계입니다.

정의와 핵심 원리

암호학적 해시는 임의 길이 입력을 고정 길이 값으로 매핑하고 역상·제2 역상·충돌 저항성을 목표로 합니다. MAC은 공유 키로 메시지 무결성과 키 소유자의 인증을 제공하며 HMAC은 해시를 안전한 키드 구조로 결합합니다.

• 일반 해시에는 비밀 키가 없습니다. 공격자가 본문과 해시를 함께 바꾸면 어느 쪽이 진짜인지 판단하기 어렵습니다. HMAC은 키와 ipad·opad를 사용하는 안쪽·바깥쪽 해시 구조입니다. 공유 키를 가진 양쪽 모두 태그를 만들 수 있으므로 제3자에게 발신자를 입증하는 용도는 전자서명과 구분합니다.

• 비밀번호 후보가 적으면 한 방향으로만 계산하는 해시라도 후보를 하나씩 대입해 찾을 수 있습니다. 레인보 테이블은 미리 계산한 연쇄를 저장해 시간과 메모리를 절충합니다. 계정별로 다른 무작위 솔트를 쓰면 같은 비밀번호의 해시가 같게 드러나지 않고 사전 계산을 재사용하기 어렵습니다. 온라인 추측과 약한 비밀번호에는 별도 대응이 필요합니다.

• 키 스트레칭은 전용 비밀번호 해싱이나 키 유도 함수(KDF)의 비용을 높여 공격자가 후보를 시험하기 어렵게 합니다. 솔트와 해시, 알고리즘과 비용을 함께 기록하고 로그인할 때 비용을 높일 수 있게 설계합니다. 별도 비밀값인 페퍼(pepper)는 솔트와 다르며 교체·복구 정책이 필요합니다.

• 변조(Modification)는 기존 자료를 권한 없이 변경하는 것으로 송금액을 10에서 100으로 바꾸는 경우입니다. 위조(Fabrication)는 허위 자료·메시지를 진짜처럼 생성·삽입하는 것으로 존재하지 않는 송금 지시를 만드는 경우입니다. 변경 탐지와 생성 주체의 진위 확인을 구분하며, 키 없는 해시만으로는 공격자가 본문과 해시를 함께 새로 만드는 것을 막지 못합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
일반 해시	비밀 키 없이 지문 생성	원본 진위·기밀성 없음
MAC/HMAC	공유 비밀 키	무결성·양자 간 인증
비밀번호 KDF	솔트·작업 비용	오프라인 추측 비용 증가

적용 예제

같은 비밀번호의 저장 비교

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: A와 B가 같은 비밀번호를 사용합니다. 솔트 sA와 sB는 서로 다릅니다.

1. 솔트 없이 동일한 해시를 적용하면 두 계정의 해시값이 같습니다.
2. KDF(password, sA, cost)와 KDF(password, sB, cost)는 서로 다른 솔트를 입력으로 계산합니다.
3. 공격자는 솔트마다 비밀번호 후보의 계산을 반복해야 합니다.
4. 온라인 속도 제한·피싱 대응·MFA도 함께 적용합니다.

결과·해석: 저장 보호와 온라인 인증 보호의 다층 관계를 설명합니다.

전제·주의: 빠른 SHA 함수를 반복 횟수 없이 비밀번호 저장에 그대로 쓰는 것은 적절하지 않습니다.

답안 골격과 혼동 방지

해시 성질 → MAC와 서명 비교 → RainbowTable → 솔트·스트레칭 → 운영 정책

- 해시는 복호하는 암호가 아닙니다.
- 솔트를 숨겨야만 안전한 비밀 키로 설명하지 않습니다.

내용을 가리고 회상

1. 해시 충돌과 역상 찾기는 어떻게 다릅니까?
2. HMAC으로 제3자에게 발신자를 입증하기 어려운 이유는 무엇입니까?
3. 솔트를 사용해도 약한 비밀번호가 위험한 이유는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- RFC2104: HMAC - H. Krawczyk et al. / IETF; 1997-02; 확인 2026-11-05.
- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.
- Internet Security Glossary, Version 2 - R. Shirey / RFC Editor; 2007-08; 확인 2026-11-05.